HL-CYB-001

Focused test plan and requirement traceability

Enterprise Zero Trust Security Architecture

Document version bdffadb4a692

T6 baseline, 2026-11-06. All operational tests below are NOT TESTED. Actual results and evidence fields are intentionally empty.

Ten focused tests check the assignment. Each includes named subchecks, not just a dashboard status. Obtain the relevant stage-specific approval before any lab action; T6 runs repository/document checks only. Home/production are never targets. The guide maps all historical R01-R16/T00-T20 IDs; no old result transfers to FWR/FWT.

1. Test governance and evidence

Before execution freeze versions, lab-owned sources/targets, synthetic user context, action/rate, expected result, evidence ID, second observation, stop and rollback. Use evidence conventions. Keep raw records private. Start every negative test with a known working allowed service/control; DNS failure or a stopped service does not prove denial.

Record PASS/FAIL/NOT TESTED for every mandatory subcheck and the test overall. PASS requires all its subchecks to pass with evidence. Missing evidence/blocked steps stay NOT TESTED and block engineering completion. Any critical safety failure blocks acceptance regardless of rubric score. No percentage rounding or 95% threshold applies to this small baseline. Engineering and separate owner UAT remain distinct.

1.1. FWT-01 - Isolation and readiness

Scope: FWR-01; FSC-01; FAC-01. Critical. Approval A and the relevant network/egress stage.

Objective and method: Confirm hardware status/ownership, delivery where needed, physical/compatibility/data-service inventory, backup/console readiness and exact destructive approvals. Inspect cables, bridge/NIC membership, routes/forwarding/IPv6, private protected aliases, other admin adapters and absence of trust/sync/credential/data reuse. Egress is disconnected or independently isolated and approved. Attempt only one scoped connection to a known listening lab-owned mock representing a protected boundary.

Expected result and pass/fail criteria: No unapproved protected path or integration; mock connection denied by intended control. No actual protected asset receives traffic. Delivery estimates never count as receipt or validation. All mandatory subchecks must pass; any observed mismatch is FAIL and any unexecuted/unverified subcheck is NOT TESTED.

Second observation: Configuration/cable inspection plus mock denial and matching policy log/counter; compare inventory with physical/firmware view. A disconnected mock alone is insufficient.

Table 1. Test governance and evidence

Record	Value
Actual result	
Evidence reference	
Operator / date / version	
Verdict	NOT TESTED

1.2. FWT-02 - Three-zone network and administration

Scope: FWR-02; FSC-02; FAC-02. Critical. Approvals B-D.

Objective and method: Count one host/four baseline VMs and exactly Management/Corporate/Restricted. Sum measured capacity versus allocations/reserves. Inspect FF-01 through FF-08 and effective

automatic/state/NAT rules. Demonstrate named admin access/MFA where supported, console recovery, WIN1-to-APP1 HTTPS permit, unlisted inter-zone listening-service denial and ordinary-user management denial. Inspect same-zone DC host policy separately.

Expected result and pass/fail criteria: Only approved source/service paths work; default deny/host policy prevent extra access. Console recovery remains available; resource ledger fits actual capacity, including temporary restore space. All mandatory subchecks must pass; any observed mismatch is FAIL and any unexecuted/unverified subcheck is NOT TESTED.

Second observation: Successful/denied sessions plus effective rules/logs and host UI/console observations; ordinary-user lack of credentials alone is not network denial.

Table 2. Test governance and evidence

Record	Value
Actual result	
Evidence reference	
Operator / date / version	
Verdict	NOT TESTED

1.3. FWT-03 - Directory, six application cases and app revocation

Scope: FWR-03; FSC-03; FAC-03. Critical. Approvals E/H and relevant endpoint scope.

Objective and method: Inspect ad.lab.test, DNS/Group Policy and project counts: ava/eli/uma, LabReaders/LabMaintainers/LabAdmins, separate privileged admin. Verify standard WIN1 logon/name resolution and no unintended privileged group. Execute C01-C06 below with known valid app credentials. Remove eli from app LabMaintainers and corresponding AD role, invalidate any relevant caches and retry an authenticated browser plus a fresh maintenance request; record elapsed time and exact changes.

Expected result and pass/fail criteria: Six case outcomes match the table; revoked maintenance permission denies both contexts. App role mapping matches approved AD roles. AD group changes alone are not treated as application revocation. All mandatory subchecks must pass; any observed mismatch is FAIL and any unexecuted/unverified subcheck is NOT TESTED.

Second observation: AD/group/resultant-policy inspection and Windows logon event; app result plus Apache authorization log/effective file. Compare committed change time to actual denial with a separate clock.

Table 3. Test governance and evidence

Record	Value
Actual result	
Evidence reference	
Operator / date / version	
Verdict	NOT TESTED

1.4. FWT-04 - Endpoint baseline and least privilege

Scope: FWR-04; FSC-04; FAC-04. Critical for privilege/bypass. Approval F.

Objective and method: Inspect supported OS/build/update status, Windows antivirus/resultant policy, both host firewalls, standard/admin membership, single zone NIC and APP1 overlay exception. Attempt one harmless administrator-only action as standard user and one approved admin control; inspect unnecessary listeners/forwarding.

Expected result and pass/fail criteria: Standard users cannot administer hosts; authorized admin works; baseline firewalls/antivirus and recorded updates are in place, without home/corporate profiles or bypass adapters. All mandatory subchecks must pass; any observed mismatch is FAIL and any unexecuted/unverified subcheck is NOT TESTED.

Second observation: OS policy/service/firewall views plus harmless standard/admin behavioral check. A version list is not vulnerability testing.

Table 4. Test governance and evidence

Record	Value
Actual result	
Evidence reference	
Operator / date / version	
Verdict	NOT TESTED

1.5. FWT-05 - HTTPS certificate trust and validity

Scope: FWR-05; FSC-05; FAC-05. Critical for false trust. Approval G.

Objective and method: Inspect one encrypted offline CA key/public root and one APP1 leaf, serverAuth/CA constraints, SAN app.ad.lab.test and current validity dates. Approved lab client trusts the public root and opens the correct HTTPS name. An otherwise functional untrusted lab client rejects the chain. Check remaining validity explicitly; do not change domain time or bypass warnings.

Expected result and pass/fail criteria: Correct chain/name/dates produce a normal HTTPS session; untrusted client rejects it. No lab trust outside approved clients. Certificate revocation services are excluded; report that limit. All mandatory subchecks must pass; any observed mismatch is FAIL and any unexecuted/unverified subcheck is NOT TESTED.

Second observation: Certificate inspection/chain check plus real browser handshake/failure. File inspection alone is insufficient.

Table 5. Test governance and evidence

Record	Value
Actual result	
Evidence reference	
Operator / date / version	
Verdict	NOT TESTED

1.6. FWT-06 - Tailscale one-resource access and revocation

Scope: FWR-06; FSC-06; FAC-06. Critical. Approval I plus isolated egress.

Objective and method: Inspect separate lab tailnet/identities/MFA/recovery, APP1/approved-client enrollment, exact TCP 443 grant, additive paths/tag owners and no routes/exit node/public share/SSH/Funnel/Serve. Inspect Linux overlay rules/forwarding and DNS. Prove approved remote HTTPS works with app roles, unauthorized user fails, wrong listening port/resource fails, then remove client grant/device authorization and test existing and new requests.

Expected result and pass/fail criteria: Only app.ad.lab.test HTTPS is reachable by the approved context; wrong identity/port and revoked client cannot access it. No production tailnet, routes, identities or credentials. Record actual revocation times/cache/state treatment. All mandatory subchecks must pass; any observed mismatch is FAIL and any unexecuted/unverified subcheck is NOT TESTED.

Second observation: Vendor/effective host policy and device state plus actual permitted/denied app sessions/logs. OPNsense alone cannot establish overlay restriction. Missing safe egress means NOT TESTED, never a relaxed permit.

Table 6. Test governance and evidence

Record	Value
Actual result	
Evidence reference	
Operator / date / version	
Verdict	NOT TESTED

1.7. FWT-07 - Five events and one denied-access investigation

Scope: FWR-07; FSC-07; FAC-07. Approval J.

Objective and method: Observe five benign events across the approved two or three sources: directory success, one failure, app allow, authenticated app denial and firewall denial. On DC1 verify account-logon auditing and appropriate Kerberos success/failure records (for example 4768/4771), rather than assuming a WIN1 interactive event is logged on DC1. Record source/observer UTC/time differences, synthetic context, event type and evidence. Investigate one denial against known working control and intended rule/group.

Expected result and pass/fail criteria: All five are attributable/searchable in the selected source views, with restricted logs/rotation. Investigation explains who requested what, why it was denied and which evidence supports that conclusion. No enterprise ingestion/retention target. All mandatory subchecks must pass; any observed mismatch is FAIL and any unexecuted/unverified subcheck is NOT TESTED.

Second observation: Source record versus actual approved action and separate policy/group observation; preserve private originals. Do not count five duplicate requests as five event categories.

Table 7. Test governance and evidence

Record	Value
Actual result	
Evidence reference	
Operator / date / version	
Verdict	NOT TESTED

1.8. FWT-08 - One automation and safe repetition

Scope: FWR-08; FSC-08; FAC-08. Approval L automation portion.

Objective and method: Review one PowerShell/Python WIN1 local-capacity summary operation: target/domain allowlist, private path, read-only query and safe invalid target/path rejection. Execute approved operation, inspect output versus OS storage view, repeat and inspect configuration/side effects.

Expected result and pass/fail criteria: Intended summary is correct; repeat changes only intended output, never configuration/accounts/network. Invalid inputs fail safely. Time/free-space fields may legitimately vary; no credential or private inventory is published. All mandatory subchecks must pass; any observed mismatch is FAIL and any unexecuted/unverified subcheck is NOT TESTED.

Second observation: OS/storage inspection separate from script output and before/after configuration review; a success flag or dry run alone is insufficient.

Table 8. Test governance and evidence

Record	Value
Actual result	
Evidence reference	
Operator / date / version	
Verdict	NOT TESTED

1.9. FWT-09 - One encrypted backup and isolated restore

Scope: FWR-09; FSC-09; FAC-09. Critical. Approval L recovery portion.

Objective and method: Verify one off-compute encrypted APP1 full backup covers declared pages/config/hashed app accounts/roles/server key/leaf/public root and recovery-key access. Restore on approved disconnected temporary ID with original off and copied Tailscale inactive. Measure restore-to-usable time, compare hashes/content and perform HTTPS allowed/denied role checks through an isolated existing client.

Expected result and pass/fail criteria: Actual scoped restore succeeds without overwriting original/sole backup or connecting duplicate identities. Record backup age/time, data/function evidence and AD/CA/host exclusions. No enterprise RPO/RTO threshold. All mandatory subchecks must pass; any observed mismatch is FAIL and any unexecuted/unverified subcheck is NOT TESTED.

Second observation: Backup/restore output plus independent clock, manifest/hash comparison and actual restored application behavior. Same-disk snapshots do not qualify.

Table 9. Test governance and evidence

Record	Value
Actual result	
Evidence reference	
Operator / date / version	
Verdict	NOT TESTED

1.10. FWT-10 - Evidence, publication and final handover

Scope: FWR-10; FSC-10; FAC-10. Critical for disclosure/false claims. Approvals K/L closeout.

Objective and method: Review all mandatory subchecks, requirements/controls/evidence/defects, five future T7 files once created, final claims and single rubric. Scan/review full proposed public set/metadata/staged diff/new history; run finalized-report, link, Office preservation, PDF/rebuild, focused tests and whitespace checks. Verify actual PR/final-head CI/merge and live main equality. Record owner UAT separately.

Expected result and pass/fail criteria: No missing mandatory evidence/unresolved safety issue. Five final files are present only after T7, sanitized artifacts/history and intentional Git publication are verified. Engineering record names actual verifier/cutoff; owner UAT stays PENDING without explicit confirmation. All mandatory subchecks must pass; any observed mismatch is FAIL and any unexecuted/unverified subcheck is NOT TESTED.

Second observation: Manual content/metadata/history and traceability review plus live GitHub read-back. Repository-only T6 checks are not PASS for this full operational handover test.

Table 10. Test governance and evidence

Record	Value
Actual result	
Evidence reference	
Operator / date / version	
Verdict	NOT TESTED

2. Six application access cases

These six cases are subchecks of FWT-03, not extra test IDs. Three permit and three deny outcomes use authenticated synthetic users on the same named HTTPS application. The maintenance path is a synthetic instruction page, not shell access.

Table 11. Six application access cases

Case	User / role	Resource	Expected
C01	ava / LabReaders	/reports/	Allow
C02	ava / no maintenance role	/maintenance/	Deny
C03	eli / LabReaders	/reports/	Allow
C04	eli / LabMaintainers	/maintenance/	Allow
C05	uma / no reader role	/reports/	Deny
C06	uma / no maintenance role	/maintenance/	Deny

The additional required revocation demonstration removes eli's maintenance role and checks existing/fresh requests. FWT-02 separately checks management/segmentation; FWT-06 separately checks remote permit/deny/revocation. None is silently included in the six-case count.

3. Coverage index

Every current requirement has a component/flow, security control, focused test, acceptance criterion and future submission owner. T7 file numbers refer to the exact filenames in the assignment/guide; they are planned, not existing artifacts.

Table 12. Coverage index

Requirement	Architecture component / flow	Security control	Test	Acceptance	T7 file
FWR-01	Physical boundary; FF-07/08	FSC-01	FWT-01	FAC-01	01
FWR-02	Host/four VMs/three zones; FF-01/02/03/05/08	FSC-02	FWT-02	FAC-02	01
FWR-03	DC1/WIN1/APP1 roles; FF-02/03	FSC-03	FWT-03	FAC-03	02
FWR-04	WIN1/APP1 host policy	FSC-04	FWT-04	FAC-04	02
FWR-05	Offline CA/APP1 HTTPS; FF-03	FSC-05	FWT-05	FAC-05	02
FWR-06	APP1/client overlay; FF-06/07	FSC-06	FWT-06	FAC-06	02
FWR-07	Firewall/DC1/Apache local logs	FSC-07	FWT-07	FAC-07	03
FWR-08	WIN1 local capacity operation	FSC-08	FWT-08	FAC-08	03
FWR-09	APP1/encrypted off-compute backup	FSC-09	FWT-09	FAC-09	03
FWR-10	Private/public boundary and handover	FSC-10	FWT-10	FAC-10	03, 04, 05

The guide transition tables preserve all sixteen old requirements and all twenty-one old test IDs without renumbering their historical evidence.